

Memcached服务安全加固

笔记本：	应用服务加固		
创建时间：	2018/11/2 21:30	更新时间：	2018/11/3 20:21
作者：	苏醒		
URL：	https://help.aliyun.com/knowledge_detail/37553.html?spm=a2c4g.11186631.2.2.1f241848UfjMeB		

漏洞描述

Memcached是一套常用的key-value缓存系统，由于它本身没有权限控制模块，所以对公网开放的Memcached服务很容易被攻击者扫描发现，攻击者通过命令交互可直接读取Memcached中的敏感信息。

修复方案

Memcached默认没有启用安全功能，建议用户在使用时进行安全加固。

Memcached服务加固方案

定期升级，使用[官方最新版本Memcached](#)

配置访问控制

建议用户不要将服务发布到互联网上而被黑客利用，可以通过[ECS安全组规则](#)或iptables配置访问控制规则。

例如，在Linux环境中运行命令**iptables -A INPUT -p tcp -s 192.168.0.2 -dport 11211 -j ACCEPT**，在iptables中添加此规则只允许192.168.0.2这个IP对11211端口进行访问。

绑定监听IP

如果Memcached没有在公网开放的必要，可在Memcached启动时指定绑定的IP地址为 127.0.0.1。例如，在Linux环境中运行以下命令：

```
memcached -d -m 1024 -u memcached -l 127.0.0.1 -p 11211 -c 1024 -P /tmp/memcached.pid
```

使用最小化权限账号运行Memcached服务

使用普通权限账号运行，指定Memcached用户。例如，在Linux环境中运行以下命令来运行Memcached：

```
memcached -d -m 1024 -u memcached -l 127.0.0.1 -p 11211 -c 1024 -P /tmp/memcached.pid
```

启用认证功能

Memcached本身没有做验证访问模块，Memcached从1.4.3版本开始，能支持SASL认证。[SASL认证详细配置手册](#)

修改默认端口

修改默认11211监听端口为11222端口。在Linux环境中运行以下命令：

```
memcached -d -m 1024 -u memcached -l 127.0.0.1 -p 11222 -c 1024 -P /tmp/memcached.pid
```

Memcached命令参数说明

-d 是指启动一个守护进程。

-m 是指分配给Memcached使用的内存数量，单位是MB，以上为1024MB。

-u 是指运行Memcached的用户，推荐使用单独普通权限用户Memcached，而不要使用root权限账户。

-l 是指监听的服务器IP地址，例如指定服务器的IP地址为127.0.0.1。

-p 是用来设置Memcached的监听端口，默认端口为11211。建议设置1024以上的端口。

-c 是指最大运行的并发连接数，默认是1024。可按照您服务器的负载量来设定。
-P 是指设置保存Memcached的pid文件，例如保存在 /tmp/memcached.pid 位置。

memcached 安装

自动安装

Ubuntu/Debian

```
sudo apt-get install memcached
```

Redhat/Fedora/Centos

```
yum install memcached
```

FreeBSD

```
portmaster databases/memcached
```

作为后台服务程序运行：

```
memcached -p 11211 -m 64m -d -u root
```

补充详细说明：

1，内网访问

最好把两台服务器之间的访问是内网形态的，一般是 Web 服务器跟 Memcache 服务器之间。普遍的服务器都是有两块网卡，一块指向互联网，一块指向内网，那么就让 Web 服务器通过内网的网卡来访问Memcache 服务器，我们Memcache 的服务器上启动的时候就监听内网的IP地址和端口，内网间的访问能够有效阻止其他非法的访问。

```
# 在 IP 192.168.0.200 的 11211 端口提供服务，占用 1024MB 内存，最大允许 1024 个并发连接
memcached -d -m 1024 -u root -l 192.168.0.200 -p 11211 -c 1024 -P /tmp/memcached.pid
```

2，设置访问控制

防火墙是简单有效的方式，如果却是两台服务器都是挂在网的，并且需要通过外网IP来访问Memcache的话，那么可以考虑使用防火墙或者代理程序来过滤非法访问。一般我们在Linux下可以使用iptables或者FreeBSD下的ipfw来指定一些规则防止一些非法的访问，比如我们可以设置只允许我们的Web服务器来访问我们Memcache服务器，同时阻止其他的访问。

```
# 清除访问控制列表
iptables -F
```

```
# 设置默认阻止
iptables -P INPUT DROP

# 仅允许主机 192.168.0.2 访问 11211 端口
iptables -A INPUT -p tcp -s 192.168.0.2 --dport 11211 -j ACCEPT
iptables -A INPUT -p udp -s 192.168.0.2 --dport 11211 -j ACCEPT
```

3, SASL 认证

在多用户环境下，可能需要为 Memcached 启用 SASL 认证，Memcached 在 1.4.3及后续版本开始支持。

要启用 SASL 认证，可能需要重新编译服务端，下面是重新编译前配置所需加入的参数：

```
./configure --prefix=${datadir} --enable-sasl
```

配置并重新编译的程序，在启动时可以追加 -S 参数，启动 SASL 认证支持。

```
memcached -S -d -m 1024 -u memuser -l 192.168.0.200 -p 11211 -c 1024 -P /tmp/memcached.pid
```

SASL认证也可以有很多种认证机制，比如shadow、pam、ldap等，下面以使用 shadow 方式认证为例介绍配置方法。

首先，修改 /etc/sysconfig/saslauthd 文件，设置认证方式：

```
vi /etc/sysconfig/saslauthd

MECH=shadow
```

然后，创建一个普通操作系统用户，执行下面的命令将用户加入 SASL 认证数据库，并绑定应用 Memcached 应用：

```
# 查看认证数据库中的绑定记录
saslpasswd2 -u memuser
# 为用户 memuser 创建 memcached 应用的认证记录
saslpasswd2 -c -a memcached memuser
```

最后，重启 saslauthd 服务，使用下面的命令测试配置是否正确：

```
# 重启服务
/etc/init.d/saslauthd restart

# 测试用户认证
testsaslauthd -u memuser -p xxxxxx
```

测试成功后就可以在客户端使用了。